

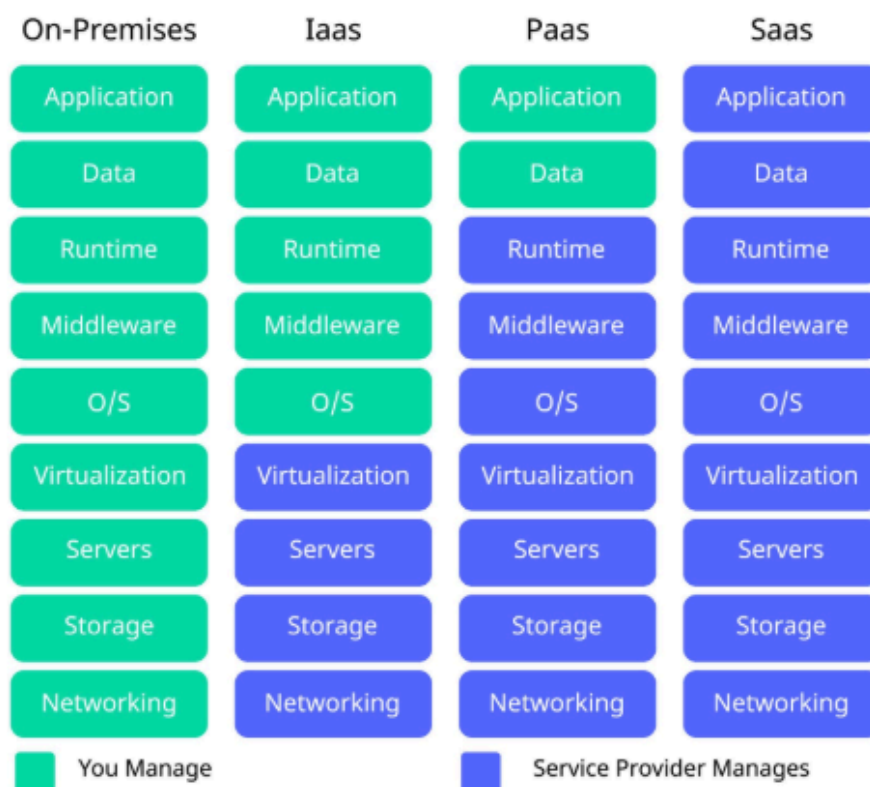
L2 - 6.1. Cloud Security Pitfalls

Task 1 - Introduction

This beginner-friendly room teaches SOC analysts how to identify and mitigate the hidden security risks and pitfalls associated with migrating from on-premises systems to the cloud.

Task 2 - What Is Cloud

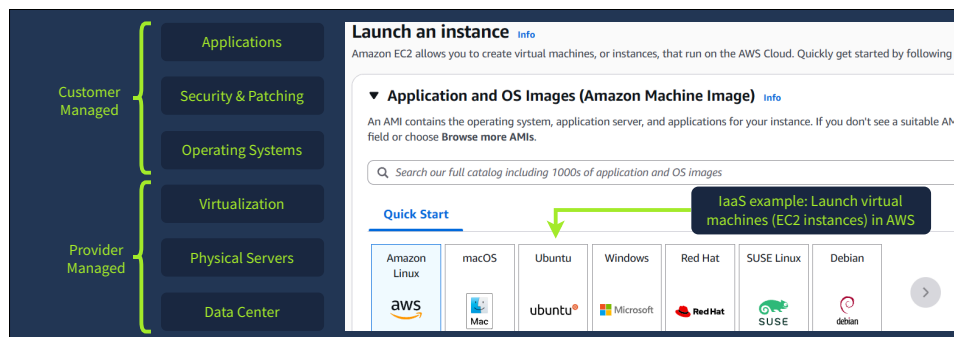
The cloud is a paradigm in which computing resources are hosted and managed by third-party providers and delivered on demand via the Internet. Users can access, configure, and pay for these services as needed, without owning or maintaining the underlying hardware. AWS, Google Drive, and even TryHackMe are all "clouds" of some sort. There are three main cloud service models you should know about: IaaS, PaaS, and SaaS.



Model	Full Form	You Manage	Provider Manages	Examples
IaaS	Infrastructure as a Service	Operating systems, runtime, data, applications	Physical hardware, networking, virtualization	AWS EC2, Azure VMs, GCP Compute Engine
PaaS	Platform as a Service	Application code, data	OS, hardware, runtime environments, middleware	AWS Elastic Beanstalk, Heroku, Google App Engine
SaaS	Software as a Service	Account access, user data settings	Entire stack (hardware, software, maintenance)	Google Drive, Microsoft 365, TryHackMe

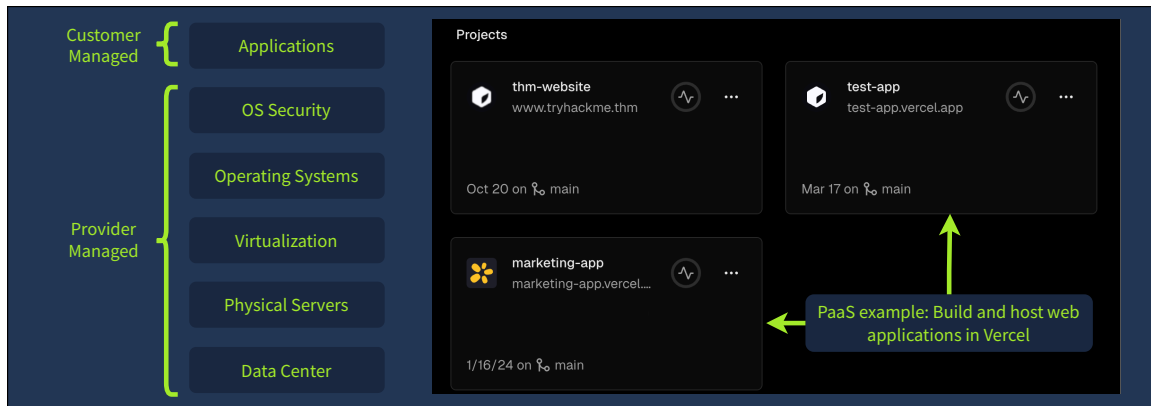
IaaS: Managing a server room or data center can be challenging: You are fully responsible for its physical security, hardware stability, software updates, network routing, and many other tasks. Every IT company needs some computing power to run its business, but not every company has the expertise or resources to maintain and properly secure its own servers.

That's the problem Infrastructure as a Service (IaaS) tries to solve. IaaS is a cloud service model where computing infrastructure is provided online on demand. For example, with an IaaS provider like Amazon AWS, Google Cloud, or Microsoft Azure, you can launch any lab machine in the cloud just by clicking a button in a web GUI, without worrying about power outages and hardware failures.



PaaS: For some companies, IaaS is not enough. For example, software developers don't want to bother with launching lab machines - all they want is to write the

source code, click a button, and see their application up and running, without caring much how and where it actually runs. Such requests are covered with Platform as a Service (PaaS) - a cloud service model for simple development and hosting web applications.



SaaS: Software as a Service (SaaS) allows users and companies to launch complex applications in the cloud without installing any software on their computers. Slack, Zoom, Gmail, Dropbox, and Google Docs are among the thousands of SaaS offerings. Unlike the previous models, SaaS is always a final product that can be used by a non-technical audience. Let's see a comparison table below for a simpler understanding:

SaaS	Not SaaS Alternative
Google Docs (Web application, saves docs in the cloud)	Microsoft Word (Desktop program, controllable updates, saves docs locally)
Dropbox (Web application, saves files in the cloud)	Synology NAS (Hardware device, can work offline, saves files locally)
MS Intune (Cloud MDM, where endpoints connect to the Microsoft servers in the cloud)	ME Endpoint Central (On-premises MDM, where endpoints connect to the local Endpoint Central server you control)

Answer the questions below

Which cloud model allows you to migrate a big on-premises network to the cloud?

IaaS

Which cloud model do Elastic Cloud and CrowdStrike Falcon fit into? Note: You may need to perform external research to answer this question.

SaaS

Task 3 - Security of the Cloud

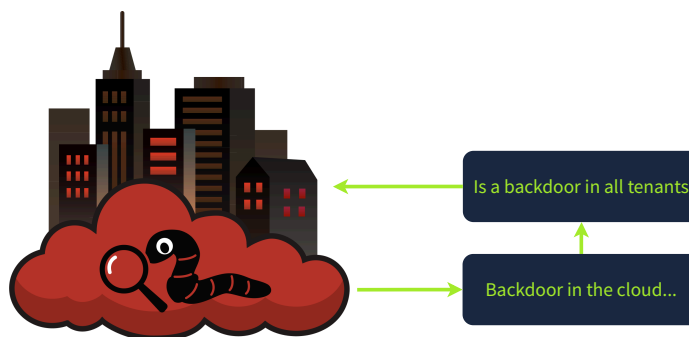
Security of the Cloud: Security of the cloud" refers to the cloud provider's responsibility to protect the underlying physical and virtual infrastructure—such as hardware, networks, hypervisors, and data centers—which remains vulnerable to attacks just like traditional on-premises systems.



Risk of Cloud Vulnerabilities: Security of the cloud" vulnerabilities present a critical supply-chain risk because even rare provider breaches can compromise high-value targets, requiring defense-in-depth measures like network segmentation, login monitoring, and endpoint analysis rather than implicit trust. Less popular cloud providers carry a significantly higher risk of compromise, making rigorous vendor vetting essential before entrusting them with sensitive data or critical workloads.



Risk of Poor Cloud Visibility: End-user lack of visibility into a SaaS provider's underlying infrastructure creates a critical blind spot where malicious activity, such as OAuth token abuse, occurs beyond the reach of internal security monitoring. For example, between August 8 and August 18, 2025, adversaries used stolen Salesloft (SaaS) OAuth tokens [to exfiltrate data\(opens in new tab\)](#) from certain SaaS customers' tenants. As an end user, you can't detect it, as the malicious activity occurred entirely within SaaS infrastructure - essentially, "someone else's computer". Third-party SaaS adoption inherently limits security logging and breeds Shadow IT, exposing sensitive data to hidden breach risks beyond SOC visibility.



Incidents of the Cloud

Cloud Provider	Security Incident Incident	Potential Impact
Okta (SaaS)	In 2023, the threat actors <u>had gained access(opens in new tab)</u> to the Okta support case management system, containing the customers' HAR files with Okta session tokens.	The attackers stealthily log in to the Okta tenants of the impacted customers.
BeyondTrust (SaaS)	In 2024, the threat actors <u>had compromised(opens in new tab)</u> some of its Remote Support SaaS instances that were used to provide remote access services to 17 customers.	The attackers gain stealthy Remote Support access to the impacted BeyondTrust customers.
Google Cloud (IaaS)	In 2025, a <u>minor vulnerability(opens in new tab)</u> in GCP Cloud Run allowed unauthorized access to the victims' container images.	The attacker accesses restricted container images or injects malicious code there.

Answer the questions below

Is the cloud provider responsible for securing and monitoring its own infrastructure (Yea/Nay)?

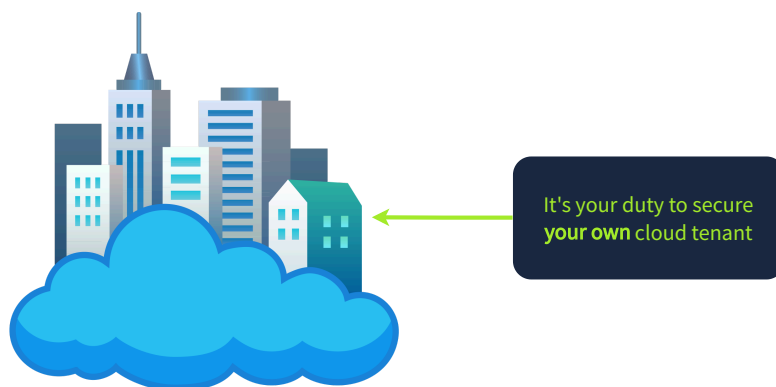
Yea

But should you trust the cloud provider without watching for supply chain threats? (Yea/Nay)

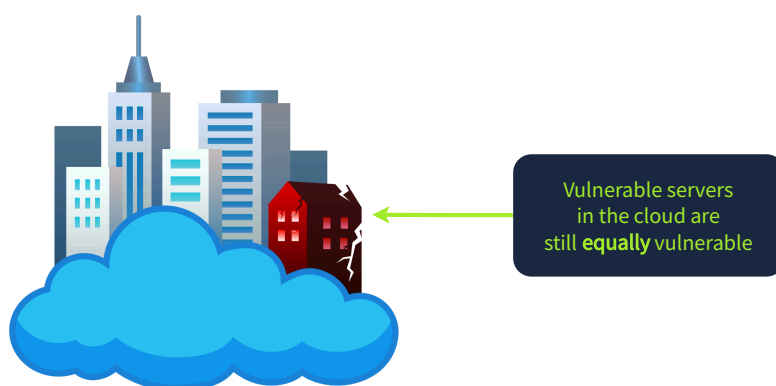
Nay

Task 4 - Security in the Cloud

Security in the Cloud: While providers secure the underlying cloud infrastructure, "Security in the Cloud" remains your responsibility—requiring the same rigorous hardening, credential management, and monitoring for your hosted VMs, built applications, and SaaS accounts as traditional on-premises systems.



Cloud Migration Pitfalls: Migrating legacy systems or data to the cloud does not magically fix existing vulnerabilities or guarantee ransomware protection—it simply shifts workloads into an environment with new, cloud-specific threat vectors that IT teams frequently overlook. Directly applying legacy on-premises security practices—like relying on simple passwords without MFA in an isolated network—creates severe vulnerabilities in public cloud environments that demand a fundamentally distinct security approach.



Logging in Clouds: Because traditional on-premises SIEM agents cannot be deployed directly onto underlying cloud infrastructure, cloud logging relies on native provider services like AWS CloudTrail to track account and resource activity. However, in the majority of cases, cloud logging is limited, especially in SaaS, where:

- **Paid Logs:** Logging to SIEM may require an additional payment or license
- **Poor Format:** Log fields may be incomplete, unstructured, or not documented
- **Lack of Integration:** In some cases, solutions don't support logging to SIEM at all

Incidents in the Cloud

Victim	Security Incident	Caused Impact
Capital One Bank	A misconfiguration in the bank's AWS resources <u>allowed the attackers</u> (opens in new tab) to access all data within the bank's S3 cloud storage.	Adversaries stole 1 million Social Insurance Numbers and 140 thousand Social Security numbers of the bank's credit card customers.
Various Companies	Hundreds of SaaS customers are breached every year due to simple mistakes, such as weak passwords, leaked API keys, or stolen cookies.	Adversaries leverage SaaS access to mine valuable information like passwords, contracts, or network maps (<u>MITRE Examples</u> (opens in new tab)).

Answer the questions below

| Does moving an unpatched server to the cloud make it secure again? (Yea/Nay)

Nay

| What is the first major obstacle to integrating most cloud products with a SIEM?

Paid Logs

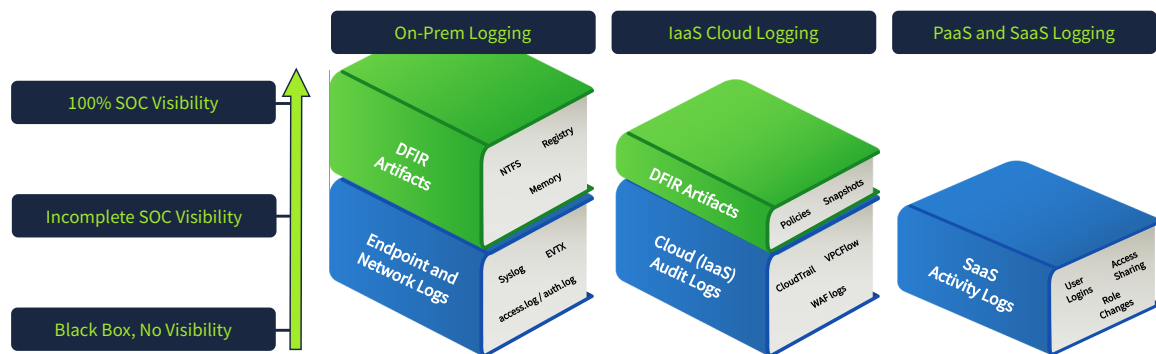
Task 5 - Cloud Security Monitoring

The effort required to secure and monitor cloud environments scales with the deployment model: while SaaS monitoring focuses on ingesting native audit logs via APIs to track risky user actions, securing IaaS demands a dual-layered approach covering both the underlying cloud configuration and the operating systems, applications, and workloads running inside the virtual instances. On the other hand, covering IaaS is a more challenging task, as you need to cover both:

- **Workloads:** Monitor IaaS machines or containers, same as in on-premises
- **Cloud Services:** Monitor database queries, storage access, and many more
- **Control Plane:** Monitor logins and actions within the cloud admin console

Data Sources for Monitoring: Cloud security monitoring forces a fundamental pivot away from traditional on-premises tools—replacing agent-based EDRs,

persistent disk forensics, and direct SIEM collectors with cloud-native audit APIs, ephemeral workload telemetry, and provider-managed log ingestion pipelines. The image below illustrates the differences in cloud and on-premises logging:



Common Cloud Security Tools: Many specialized solutions begin to pop up to cover what traditional tools can't cover in the clouds. Cloud Access Security Brokers (**CASB**) enforce security policies, Cloud Workload Protection Platforms (**CWPP**) protect against malware, Cloud Security Posture Management (**CSPM**) alert on misconfigurations, and so on. While we encourage you to read about them more, you can still set up monitoring just with SIEM and have a decent SOC coverage:

Recommended Action	Description
1. List your clouds	Identify all cloud platforms where your organization stores or processes critical data
2. Know the risks	Prepare a plan for a potential cloud vendor's breach, even if the likelihood is low
3. Enable cloud logs	Turn on vendor-provided cloud audit logs in all identified clouds, including SaaS
4. Enable workload logs	For IaaS, don't forget that your VMs require the same logging as in on-premises
5. Collect the logs	Forward the logs to your SIEM, as they aren't kept in the cloud for a long time
6. Monitor for anomalies	Build SIEM detection rules by alerting on suspicious logins and administrative actions

Answer the questions below

What term describes cloud compute resources like VMs or containers?

Workloads

Which of the mentioned cloud security tools do Falco and Tetragon fit into?

Note: You may need to perform external research to answer this question.

CWPP

Task 6 - Challenge

Cloud Security Challenge: In this task, you will explore the differences between cloud service models and repeat the Shared Responsibility Model - what you manage versus what the vendor manages. Visit the static site below, complete the exercises, and get the flags!

Answer the questions below

What is the flag you get after completing the first exercise?

THM{flag_as_a_service!}

The screenshot shows a web application interface for a cloud service model exercise. At the top, a blue header bar contains the title 'Choose the Correct Cloud Service Model' and a sub-header 'Exercise 1 of 2'. Below the header, a blue bar with white text reads: 'Learn the difference between IaaS, PaaS, and SaaS models. Move each cloud service model description from the left onto the correct column.' The main area is divided into four columns. The first column is labeled 'POOL' and contains a box with the text: 'Amazon AWS, Google Cloud, and Microsoft Azure are some of the examples'. The second column is labeled 'IaaS' and contains two boxes: 'Provides an ability to launch and use Linux or Windows VMs in the cloud' and 'Requires the most effort to learn, configure, harden, secure, and monitor'. The third column is labeled 'PaaS' and contains three boxes: 'Allows you to quickly build applications without maintaining servers', 'Popular examples include Azure App Service and Google App Engine', and 'Is a balance between maintaining VMs and simply using software in the cloud'. The fourth column is labeled 'SaaS' and contains three boxes: 'Asana, Confluence, Salesforce, and DrawIO are some of the examples', 'Can be used by non-technical departments, such as Sales, Marketing or Design', and 'Ready to use right after you sign up, doesn't require much configuration'. At the top right of the interface, there is a '1 to place' indicator and a 'View flags' button.

What is the flag you get after completing the second exercise?

THM{ready_for_cloud_migration!}

Choose the Responsible Person in IaaS Exercise 2 of 2 1 to place View flags

In IaaS, some responsibilities are yours, others belong to the provider. Drag each statement under the correct column.

POOL	You	IaaS Provider
Patch vulnerabilities in cloud-managed services, such as AWS S3	Detect suspicious logins of cloud users within your IaaS tenant	Secure the cloud datacenters from unauthorized physical access
	Collect VM logs and monitor the launched workloads for cyber threats	Protect against supply chain attacks on cloud admin panel
	Control access to data in cloud-managed services, such as AWS S3	
	Manage software dependencies in the virtual machines you launch	

Task 7 - Conclusion

Securing modern cloud environments requires moving past legacy on-premises mindsets, recognizing the distinct security models across IaaS, PaaS, and SaaS, and adopting cloud-native logging techniques to overcome visibility gaps and effectively monitor emerging threats.